

Sentinelleai — Audit Report

CronosCreateTokenReceiver.sol · 864c3322-43dc-4088-bbe9-a717199da65b · 2026-06-08
09 h 04 min 18 s

CAUTION 72 / 100 3 consolidated findings

CronosCreateTokenReceiver demonstrates solid EIP-712 intent verification, replay protection, and a well-designed separation between the relayer (gas-payer) and creator (signer) roles. The two static-sentinel false positives (ZAD-1 and AST-MISSING-ACCESS-CONTROL) are refuted by explicit checks in the code: `setRelayer` contains a zero-address guard and `executeCreate` gates on `msg.sender == relayer` before any state mutation. The primary confirmed risk falls under OWASP SC01 (Access Control): the contract uses single-step Ownable rather than Ownable2Step, and the owner EOA can unilaterally rotate the relayer, whitelist arbitrary source chains, and pause/unpause the contract without a timelock or multisig. Historian's analysis correctly elevates this to HIGH given the 2025-2026 pattern of admin-key compromises on bridge/relayer infrastructure (Drift, IoTeX). A compromised owner key could silently redirect all future token-creation intents to an attacker-controlled relayer or whitelist a malicious source chain. No reentrancy, arithmetic, or cross-chain forgery risks were identified by any agent.

Severity breakdown

1 HIGH 1 LOW 1 INFO

Static sentinel pre-scan

Static sentinels (EVM/Solidity) matched 3 pattern(s) — 1 HIGH, 2 LOW.

LOW SC01 · OWN-1 · line 58

Single-step Ownable (no Ownable2Step)

Ownership transferred to a wrong address is irreversible. Ownable2Step requires the new owner to accept, preventing typos and lost keys.

```
contract CronosCreateTokenReceiver is Ownable
```

LOW SC01 · ZAD-1 · line 136

Setter accepts zero-address (no validation)

set*(address _x) functions that write the parameter directly to state can brick the protocol if called with address(0). Add require(_x != address(0)).

```
function setRelayer(address _relayer) external onlyOwner { if (_relayer ==  
address(0)) revert ZeroAddress(); emit RelayerUpdated(relayer, _relayer); relayer =  
_relayer; }
```

HIGH SC01 · AST-MISSING-ACCESS-CONTROL · line 181

External state-mutating function lacks access control

An external/public, non-view function that writes to state without an onlyOwner / role / msg.sender check is callable by anyone. Even if the name doesn't match a privileged-keyword whitelist, the lack of any gate is suspicious.

```
function executeCreate( uint256 sourceChainId, address sourceGateway,  
CreateTokenIntent calldata intent, bytes calldata signature ) external nonReentrant  
whenNotPaused returns (address token) { //
```

Consolidated findings

HIGH CVSS 7.2 SC01 — Access Control

Single-EOA Owner Controls Critical Admin Functions Without Timelock or Multisig

The contract inherits OpenZeppelin's single-step Ownable, meaning a single EOA can unilaterally call `setRelayer` (rotate the gas-payer/submitter), `setTrustedSource` (whitelist arbitrary source chains and gateways), `pause`, and `unpause`. A compromised or malicious owner key can silently redirect all token-creation intents to an attacker-controlled relayer or introduce a rogue trusted source domain, undermining the entire cross-chain security model. This matches the 2025-2026 pattern of admin-key compromises on bridge/relayer infrastructure (Drift ~\$285M Apr 2026, IoTeX ~\$4.3M Feb 2026). The static sentinel OWN-1 is confirmed by multiple agents.

lines 58, 136, 141-145, 158, 161, 164

→ 1) Replace Ownable with Ownable2Step so ownership transfers require acceptance. 2) Protect `setRelayer` and `setTrustedSource` with a 48-hour timelock (e.g., OpenZeppelin TimelockController). 3) Transfer ownership to a Gnosis Safe multisig requiring M-of-N signatures. 4) Emit events and consider an off-chain monitoring alert for any admin action.

Confirmed by: [developer](#), [historian](#), [static-sentinel-OWN-1](#)

LOW CVSS 2.0 SC01 — Access Control

Static Sentinel ZAD-1: setRelayer Zero-Address Check — False Positive

The static sentinel flagged `setRelayer` as potentially accepting `address(0)`, but the function explicitly contains `'if (_relayer == address(0)) revert ZeroAddress();'` before writing to state. This is a false positive; the validation is correctly implemented.

line 136

→ No action required. The zero-address guard is already present.

Confirmed by: [developer](#), [historian](#)

INFO CVSS 0.0 SC01 — Access Control

Static Sentinel AST-MISSING-ACCESS-CONTROL: executeCreate Access Control — False Positive

The static sentinel flagged `executeCreate` as lacking access control. In fact, the function's first check is `'if (msg.sender != relayer) revert NotRelayer();'`, which restricts submission to the designated relayer. The creator is further bound by EIP-712 signature verification, not `msg.sender`. This is a false positive from the deterministic regex rule.

line 181

→ No action required. Access control is correctly implemented per the documented design intent.

Confirmed by: [developer](#), [historian](#)

Historical precedents

Retrieved from the local bug-bounty corpus (~20 700 findings) by vulnerability-class match.

CRITICAL access-control solana 2022-02-02 **\$320 000 000**

Bridge — guardian-set signature verification bypass via missing Signer check

<https://rekt.news/wormhole-rekt/>

CRITICAL access-control solana 2026-04-01 **\$285 000 000**

Drift Trade — Compromised Admin + Fake Token Price Manipulation

CRITICAL access-control solana 2022-03-23 **\$48 000 000**

Stablecoin mint — missing has_one between bank and collateral accounts

<https://rekt.news/cashio-rekt/>

MEDIUM bm25 2023-10-01

zksync — The `upgrade()` function lacks access control

<https://github.com/code-423n4/2023-10-zksync-findings/issues/120>

MEDIUM bm25 2023-09-01

maia — privileged administrator function lacks access control

<https://github.com/code-423n4/2023-09-maia-findings/issues/5>

HIGH bm25 2024-01-01

curves — The `FeeSplitter.setCurves` function lacks an access control modifier

<https://github.com/code-423n4/2024-01-curves-findings/issues/478>

HIGH bm25 2023-09-01

maia — RootBridgeAgentFactory.createBridgeAgent() lacks access control.

<https://github.com/code-423n4/2023-09-maia-findings/issues/379>

HIGH bm25 2024-01-01

curves — FeeSplitter.setCurves lacks access control.

<https://github.com/code-423n4/2024-01-curves-findings/issues/1192>

MEDIUM bm25 2024-05-01

loop — The contract lacks of a setter to disallow a token

<https://github.com/code-423n4/2024-05-loop-findings/issues/87>

HIGH bm25 2023-09-01

maia — Virtual account lacks access control

<https://github.com/code-423n4/2023-09-maia-findings/issues/888>

MEDIUM bm25 2024-01-01

curves — `FeeSplitter::setCurves()` lacks access control

<https://github.com/code-423n4/2024-01-curves-findings/issues/934>

MEDIUM bm25 2023-09-01

maia — Lack of access control checks in the Ownable contract, important functions, such as execute, executeSigned, and others, do not have access control checks

<https://github.com/code-423n4/2023-09-maia-findings/issues/44>

Generated by Sentinelleai on 2026-06-08T13:08:43.953Z. Audit ID: 864c3322-43dc-4088-bbe9-a717199da65b.

This report combines deterministic regex+AST sentinels, optional Slither/Mythril static analysis, and a 6-model adversarial LLM panel consolidated by a Judge agent.